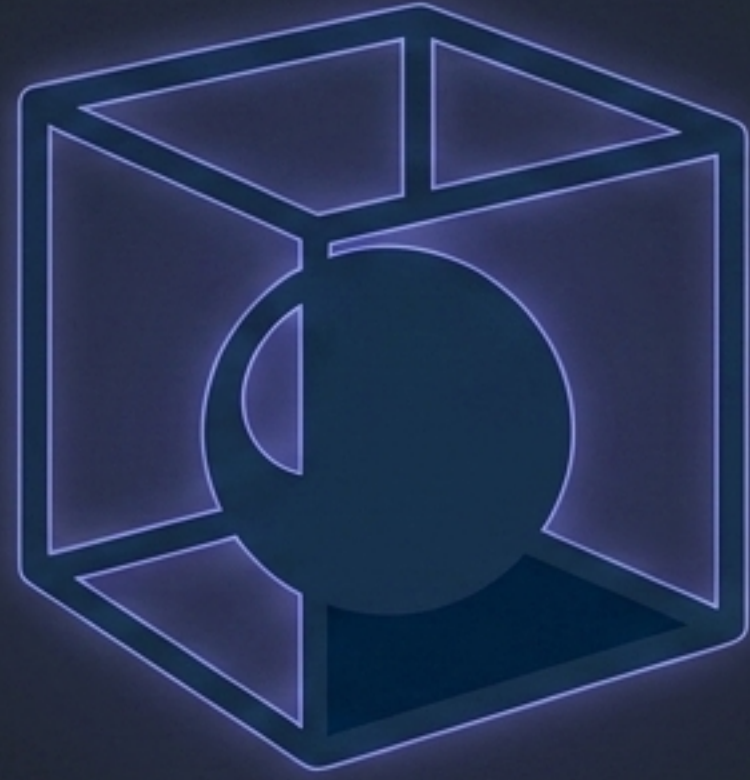




Architecting AI Trust

Securing the shift from coding assistants
to autonomous agentic systems.

THE AI TRUST DEFICIT: MOMENTUM VS. FRICTION

82% of developers use AI coding assistants daily or weekly.

Only 28% trust that AI-generated code is secure and production-ready.

THE TRUST DEFICIT:
AI generates code faster than traditional AppSec can secure it. This friction results in 76% of developers experiencing frequent hallucinations or mistakes, demanding constant manual verification.

	Generative AI (Copilots)	Autonomous AI (Agentic Systems)
Trigger	Human-prompted execution.	Autonomous event-driven workflows.
Action	Inline code suggestions and scaffolding.	Tool chaining, API invocation, and self-directed logic execution.
Key Vulnerability	Hallucinations (e.g., fabricating open source dependencies).	Prompt injection, cascading trust failures, and memory manipulation.
Security Control	Shift-left SAST / SCA scanning.	Runtime monitoring, strict sandboxing, and continuous agent red-teaming.

Exploiting Model Merges

Collaborative training models (e.g., hosted on Hugging Face) have been found harboring malicious payloads that infect downstream agentic frameworks.

Agent Core

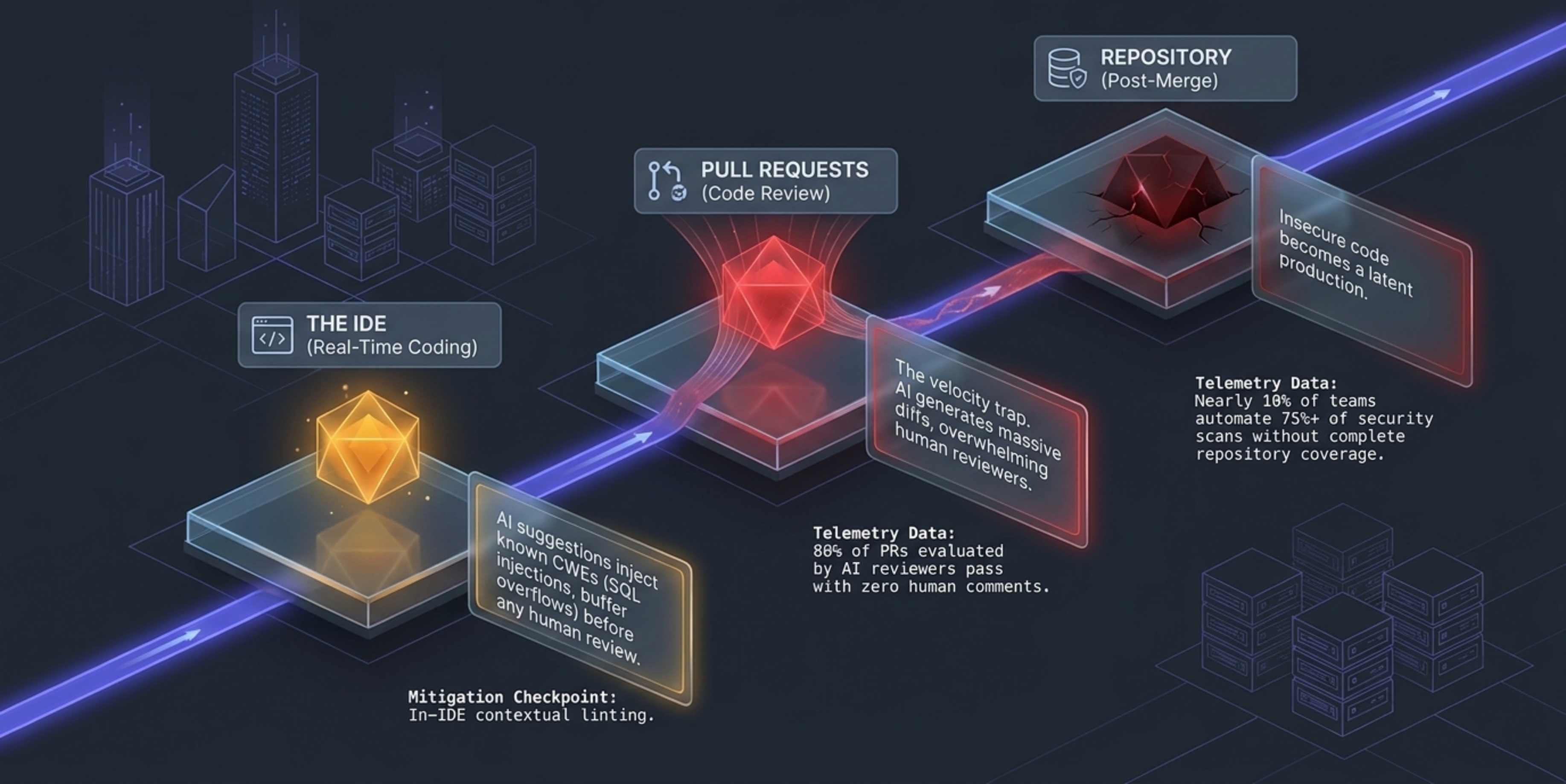
The Hallucination Supply Chain

Up to 21% of AI-generated dependencies in test samples link to nonexistent libraries—creating attack paths for malicious actors to register hallucinated package names.

Multi-Agent Contamination

OWASP identifies agent-to-agent communication poisoning, where one compromised agent alters the decision-making of the entire chain.

THE AI DEVELOPMENT LIFECYCLE RISK PIPELINE





Traditional AppSec (Static Policies)

Method: One-size-fits-all binary rules (Block/Allow).

Timing: Periodic scans or late-stage CI/CD gates.

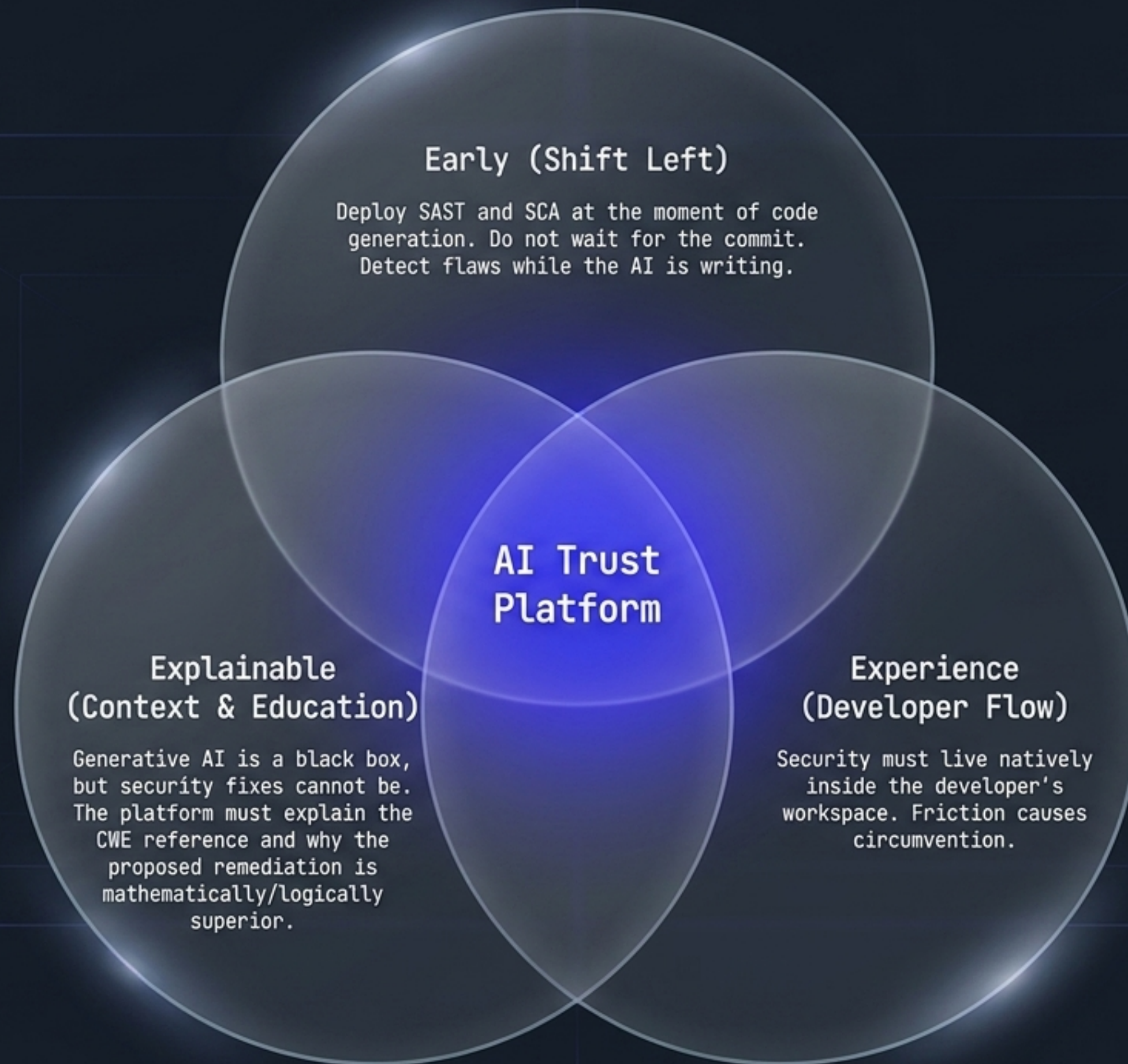
Result: Developer friction, ignored warnings, and delayed releases.

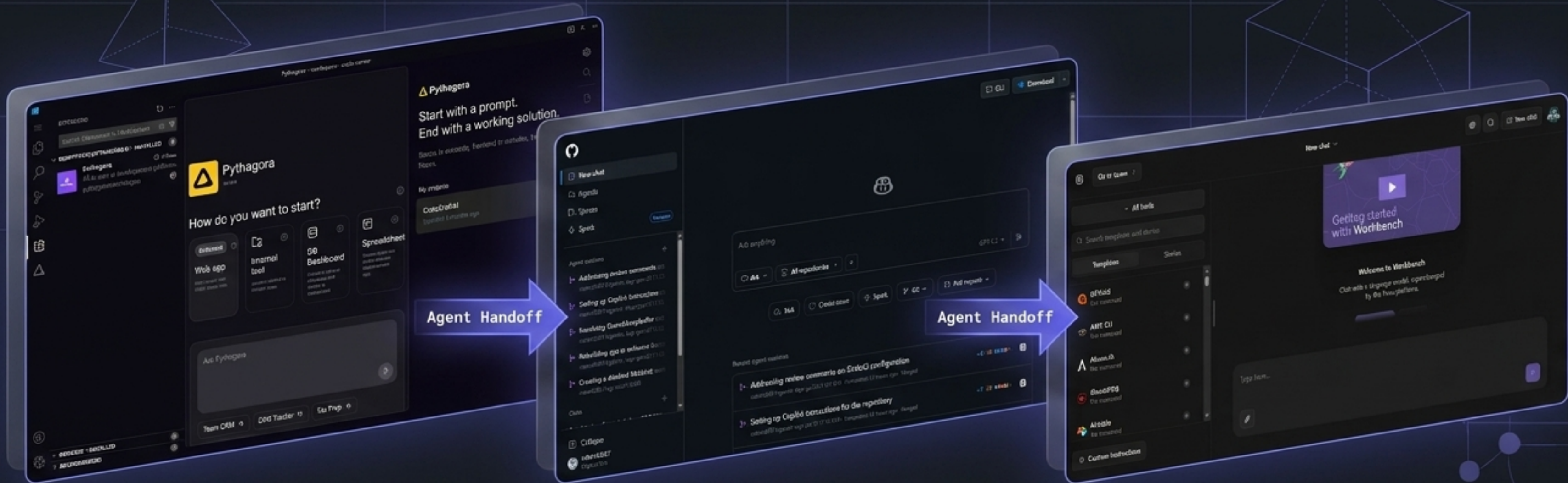
Adaptive Guardrails (Contextual Risk Scoring)

Method: Real-time policy enforcement tuned by context (developer history, code path criticality).

Timing: Continuous, originating at the IDE via Model Control Protocol (MCP).

Result: Up to 60% faster Mean Time to Remediate (MTTR) for teams integrating security natively into AI workflows.





Step 1: The Prompt (Pythagora Workspace)

Start with a prompt. End with a working solution. The human defines the architectural intent.

Step 2: Agent Orchestration (GitHub Agent UI)

Autonomous agents break down the prompt—addressing review comments, setting up configurations, and resolving thread errors without human input.

Step 3: External Invocation (Tines Workbench)

The agent reaches outside the IDE, triggering API workflows to validate external inputs and align with infrastructure policies.

Project: The Slovak Copilot (Localized AI IT Assistant)

Financial & Timeline

Velocity Timeline:
5 Months from Concept to Public Deployment.

Financial Efficiency:
€17,580 Total Budget (65% allocated directly to AI Specialist/Dev).

Operational KPIs

30

Testujúci používatelia
(Pilot Testers)



500

Interakcií
(System Interactions)



5

Implementovaných modulov
(Core AI Modules)



80%

Miera spokojnosti
(User Satisfaction Rate)



Key Takeaway: Specialized, localized AI agents do not require massive enterprise budgets if the architecture is highly focused.

True DevSecOps for AI requires specialized, context-aware platforms.

You cannot secure an autonomous Agentic system with generic, static tools. The next evolution of software is not just apps built by AI, but apps that use AI to continuously monitor their own structural integrity, compliance risks, and operational data.



Enter the Sovereign Architect.

The Interface Layer

`app/layout.tsx`

Dynamic dashboards tracking
€3-5M EU/US grants running
in an ultra-modern dark
mode.

The Agentic Logic

`api/grants/evaluate/
route.ts`

Routing nodes where the AI
agent actively scores grant
fit and generates risk
explanations.

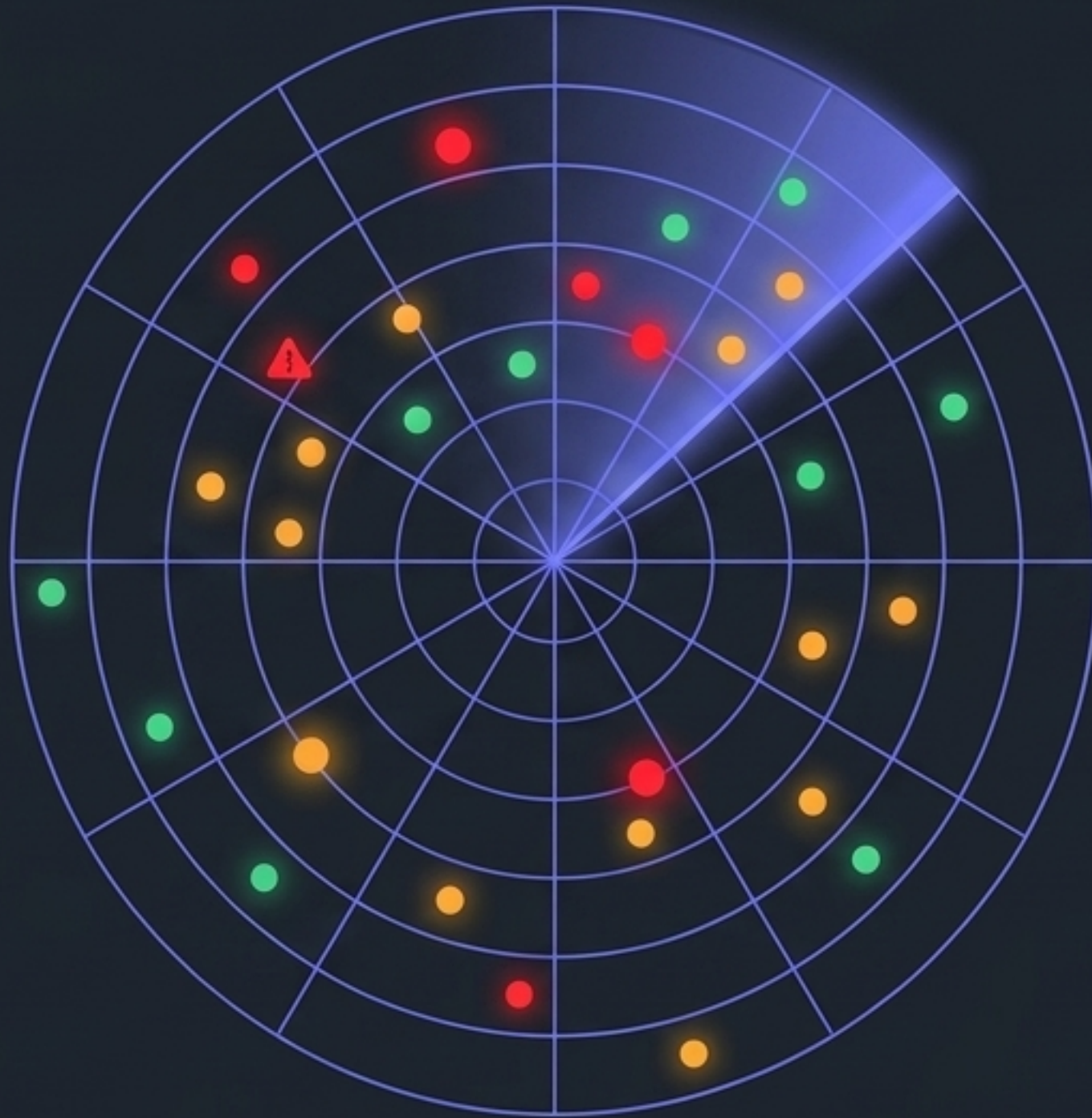
The Semantic Foundation

`components/ui/
Badge.tsx`

`components/ui/Card.tsx`

Strictly enforcing semantic
risk indicators (Low:
Emerald, Medium: Amber,
High: Red) to ensure
explainability at a glance.

Raw Telemetry



Contextual Mode Output: EU + US Blended Compliance

AI Act Classification: System flagged as high-risk for public sector decision support.

[DANGER]

Data Residency: Primary storage in EU with US read replicas.

[MEDIUM]

Procurement Rules: Awaiting confirmation on framework contract.

[LOW]

State Aid / De Minimis: Cross-border relevance requires continuous tracking.

[MEDIUM]



RMD26

Assume Vulnerability at AI Speed

Recognize that generative models will introduce OWASP top-tier flaws (injection, memory corruption). Shift security left to the exact moment of code creation (IDE).

Mandate Adaptive Guardrails

Replace rigid, binary application security policies with contextual, real-time risk scoring that evaluates developer history and code criticality.

Architect for Autonomy

As we transition to multi-agent workflows, implement dynamic compliance radars and continuous agent red-teaming to secure non-deterministic logic.

The future belongs to organizations that balance AI velocity with structural trust.